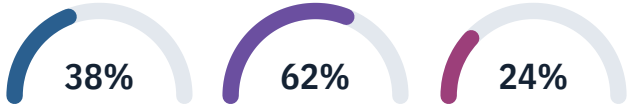
God's Eye View: from audit to compliance

CrossCheck audited God's Eye View against three global standards: **EUROCAE ED-153** for software safety assurance at SWAL 3, **OWASP ASVS 5.0** for application security at Level 2, and **ISO/IEC 42001** for managing AI responsibly. This plan closes every gap it found, in four waves, with each fix evidenced line by line.

1	2	3	4	5	6	7	8	9
Baseline frozen 2026-10-14	**Audit** 2026-10-14	**Plan issued** 2026-10-14	**Plan approved** 2026-10-14	**Wave 1 · Harden** next	**Wave 2 · Control access** planned	**Wave 3 · Prove safety** planned	**Wave 4 · Assure and hand over** planned	**Evidence pack issued** planned

WHERE WE START · BASELINE 1518EA8



Safety · ED-153
SWAL 3 claim not supported

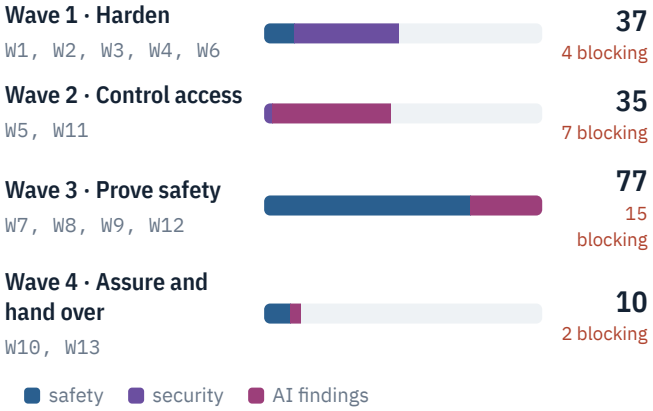
Security · ASVS L2
ASVS L2 not met

AI · ISO 42001
ISO 42001 not met

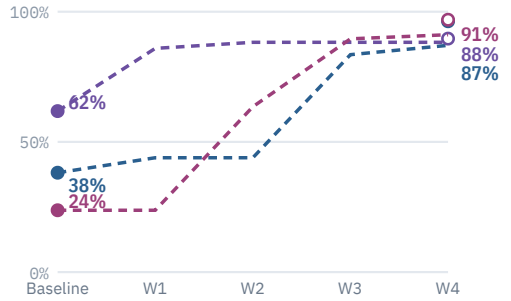
159 findings: 72 safety, 31 security, 56 AI. **28** of them block a claim.

HOW THE GAPS ARE CLOSED

159 findings → 13 workstreams → 4 waves



READINESS JOURNEY



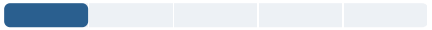
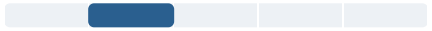
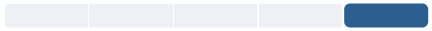
safety · security · AI · ● measured · dashed: target with Claude + Replit · ○ with customer and independent reviewer

1. **Wave 2:** ASVS Level 2 met; AI policy, scope and intended use in place.
2. **Wave 3:** no AI must-fix left.
3. **Wave 4:** safety 87%, AI 91%; human-only steps (9) then take the SWAL 3 claim to supported and ISO 42001 to met.

READING THIS RECORD · 0 This page · 1 Waves · 2 Workstreams · 3 Line by line, every finding · A Method and rules

Four waves, each ending in a re-audit

Waves 1–2 close the security gaps in code; Wave 2 also sets up the AI management system. Waves 3–4 build the safety evidence that ED-153 asks for and the AI risk, impact and audit records ISO 42001 asks for. Wave 3 can start alongside Wave 2 if a safety lead is free.

WAVE	WORKSTREAMS	WEEKS 1 → 5	EXIT CHECK
Wave 1 · Harden Engineering · 1 week	W1 Web hardening W2 Abuse resistance and availability W3 Supply chain and secrets W4 Logging and monitoring W6 Data and validation rules		Every Wave 1 security finding closed except V8; re-audit
Wave 2 · Control access Engineering + customer identity provider · 1 week	W5 Access control W11 AI management system		ASVS Level 2 met; AI policy, AIMS scope and intended use issued; re-audit
Wave 3 · Prove safety Safety lead, engineering, customer · 2–3 weeks	W7 Safety analysis W8 Safety plan, process and configuration management W9 Requirements, verification and validation W12 AI risk, impact and monitoring		No S1–S2 safety or High AI finding open
Wave 4 · Assure and hand over Safety lead, independent reviewer · 1 week	W10 Safety case and release evidence W13 AIMS audit and review		SWAL 3 claim supported; first AIMS internal audit done; evidence pack issued

Only the customer or owner can do these

ACTION	NEEDED BY
Choose the identity provider	Wave 2
Confirm the operational context; join the hazard assessment	Wave 3
Name the plan approver and an independent reviewer	Wave 3
Restrict browser keys in the Google and Cesium consoles	Wave 1

ACTION	NEEDED BY
Validate with operational users	Wave 3
Approve the AI policy and name an AI owner	Wave 2
Hold the AI management review	Sign-off

Not ours to give: final ED-153 acceptance needs an independent assessor, the customer's operational context, and a check of CrossCheck's reconstructed catalogue against a purchased copy of ED-153. ISO/IEC 42001 certification needs an accredited certification body.

13 workstreams; each finding belongs to exactly one

W1 Web hardening

Wave 1

6 security 1 blocking

- Security headers on every response: HSTS, nosniff, Referrer-Policy and a Content-Security-Policy with script-src.
- Inline HTML templates moved so the policy can drop unsafe-inline.

Evidence: Header tests in the preview-serving suite; a browser-captured policy report.

W2 Abuse resistance and availability

Wave 1

1 safety 5 security

1 blocking

- Rate limiting on by default for every cost-bearing proxy, with global caps.
- Client IP taken from the forwarded header only when the request comes through the known proxy hop.

Evidence: Limiter tests; a load test against the deployed app.

W3 Supply chain and secrets

Wave 1

4 safety 6 security

1 blocking

- npm audit and Dependabot in CI; CI fails on High or Critical.
- CycloneDX software bill of materials (SBOM) for each release; patch time limits in SECURITY.md.

Evidence: CI logs; SBOM file; dossiers; console screenshots.

W4 Logging and monitoring

Wave 1

3 safety 8 security

1 blocking

- Structured JSON logs with UTC timestamps and request IDs; untrusted values encoded.
- Security events logged: rate-limit hits, validation rejects.

Evidence: Logger tests; log inventory; an alert fired in test.

W5 Access control

Wave 2

2 security 2 blocking

- Sign-in through an external identity provider (OIDC); roles viewer, operator, admin.
- Server-side checks on every function; paid proxies need operator; Exercise mode needs an explicit role.

Evidence: Access-control test matrix (role × endpoint); CrossCheck assessment of the new V6, V7, V9 and V10 rows.

W6 Data and validation rules

Wave 1

4 security 0 blocking

- Input-validation specification per API endpoint: types, ranges, lengths, combined-field rules.
- Data classification (public, aggregated-sensitive, simulated) with handling rules for caching, export and retention.

Evidence: Both documents, each validation rule traced to an existing test.

W7 Safety analysis

Wave 3

10 safety 8 blocking

- Concept of operations: users, environment, advisory-only boundary.
- Functional hazard assessment: failure modes per component, effects on the operator, justified likelihood.

Evidence: Versioned analysis documents reviewed with the customer.

W8 Safety plan, process and configuration management

Wave 3

29 safety 3 blocking

- Software safety assessment plan: approach, rigour per SWAL, I/R/D classification, named reviewer sign-off.
- Development plan with an AI-assistance policy: no tool credit, human review of every AI change.

Evidence: Approved plans; repository settings evidence; release records.

W9 Requirements, verification and validation

Wave 3

18 safety 1 blocking

- Reviewed and approved SRS covering the inherited layer engine; traceability widened from 56 requirements.
- Dead-code review (remove /api/route); isolation argument per first-level component.

Evidence: Review records, test reports, validation minutes.

W10 Safety case and release evidence

Wave 4

7 safety 2 blocking

- Software safety assessment report with a GSN-style argument (direct and back-up).
- Software safety folder; assessment report and distribution record per release; independent audit.

Evidence: Issued safety folder and independent audit report.

W11 AI management system

Wave 2

33 AI 5 blocking

- AIMS scope and manual: which AI uses are covered (Director, narration, AI-assisted development, HENRI).
- AI policy with the advisory-only boundary and principles; roles (AIMS owner, AI risk owner); objectives.

Evidence: Issued AIMS manual, policy, intended-use statement and supplier register; disclosure visible in the app.

W12 AI risk, impact and monitoring

Wave 3

20 AI 3 blocking

- AI risk assessment and treatment with a statement of applicability for Annex A.
- Impact assessments: individuals and groups, societal and dual-use effects of a public military-asset picture.

Evidence: Risk register, impact assessments, event-log samples, validation record.

W13 AIMS audit and review

Wave 4

3 AI 0 blocking

- AIMS internal audit programme (CrossCheck as the method, an independent auditor for sign-off).
- Management review minutes; continual-improvement log in the evidence ledger.

Evidence: Audit report and management-review minutes.

Every finding, its fix and how it will be closed

"Closed by" is filled from the ledger as fixes land: a commit SHA, test or document reference, with the date and new rating in CrossCheck.

W1 Web hardening

Wave 1 · 6 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V3.2.1 ASVS	Security controls are in place to prevent browsers from rendering content or functionality in HTTP responses in an incorrect context (e.g., when an... V3 Web Frontend Security	Partial	Medium	Add nosniff and a CSP (see V3.4.3, V3.4.4).	API responses set Content-Type; no X-Content-Type-Options or CSP sandboxing.	open
V3.4.1 ASVS	A Strict-Transport-Security header field is included on all responses to enforce an HTTP Strict Transport Security (HSTS) policy. A maximum age of at... V3 Web Frontend Security	Non-compliant	Medium	Set HSTS (max-age >= 1 year) in server headers or at the edge.	No Strict-Transport-Security header set by the app; edge behaviour on Replit unverified.	open
V3.4.3 ASVS	HTTP responses include a Content-Security-Policy response header field which defines directives to ensure the browser only loads and executes trusted... V3 Web Frontend Security	Non-compliant	High	Ship a script-src CSP (nonces or hashes) after moving inline HTML templates.	CSP is frame-ancestors only; no script-src/object-src/base-uri (SECURITY.md known gap 2).	open
V3.4.4 ASVS	All HTTP responses contain an 'X-Content-Type-Options: nosniff' header field. This instructs browsers not to use content sniffing and MIME type... V3 Web Frontend Security	Non-compliant	Medium	Add nosniff to server.headers.	X-Content-Type-Options: nosniff not set.	open
V3.4.5 ASVS	The application sets a referrer policy to prevent leakage of technically sensitive data to third-party services via the 'Referer' HTTP request header... V3 Web Frontend Security	Partial	Low	Set Referrer-Policy: strict-origin-when-cross-origin explicitly.	No explicit Referrer-Policy; browser default strict-origin-when-cross-origin applies.	open
V13.4.5 ASVS	Documentation (such as for internal APIs) and monitoring endpoints are not exposed unless explicitly intended. V13 Configuration	Partial	Low	Remove or gate the debug handle in production.	window.__godsEyeView debug handle exposed in production builds.	open

W2 Abuse resistance and availability

Wave 1 · 6 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V2.4.1 ASVS	Anti-automation controls are in place to protect against excessive calls to application functions that could lead to data exfiltration, garbage-data... V2 Validation and Business Logic	Partial	High	Enable limits by default; add global quota caps and alerting on provider spend.	Opt-in per-IP limiter (default unlimited); cost-bearing Google proxies callable by anyone with the URL.	open
V2.3.2 ASVS	Business logic limits are implemented per the application's documentation to avoid business logic flaws being exploited. V2 Validation and Business Logic	Partial	Medium	Turn rate limiting on by default in production config.	Limits exist but per-IP rate limiting is opt-in and off by default.	open
V15.3.4 ASVS	All proxying and middleware components transfer the user's original IP address correctly using trusted data fields that cannot be manipulated by the... V15 Secure Coding and Architecture	Partial	Medium	Trust the platform's forwarded header only from the known proxy hop.	Limiter ignores X-Forwarded-For, so behind the Replit proxy every client may share one bucket.	open
V2.1.3 ASVS	Expectations for business logic limits and validations are documented, including both per-user and globally across the application. V2 Validation and Business Logic	Partial	Medium	Document per-client and global limits for each cost-bearing proxy.	Rate limits and provider budgets described in CONFIGURATION-INDEX; no per-client/global limit policy.	open
V15.1.3 ASVS	The application documentation identifies functionality which is time-consuming or resource-demanding. This must include how to prevent a loss of... V15 Secure Coding and Architecture	Partial	Low	Document heavy endpoints (Overpass, routes, tracks) and their limits.	KNOWN-LIMITATIONS and provider budgets cover upstream cost; no list of resource-heavy endpoints.	open
4.3.13 ED-153	Resource management (load, memory, time response) 4.3 Development	Partial	S4	Resource budgets (frame time, memory, latency).	Benchmark, adaptive quality ladder, caps.	open

W3 Supply chain and secrets

Wave 1 · 10 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V15.2.1 ASVS	The application only contains components which have not breached the documented update and remediation time frames. V15 Secure Coding and Architecture	Non-compliant	High	Add npm audit and Dependabot; fail CI on high/critical.	No dependency vulnerability scanning in CI (SECURITY.md known gap 4); state cannot be shown.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V15.1.1 ASVS	Application documentation defines risk based remediation time frames for 3rd party component versions with vulnerabilities and for updating libraries... V15 Secure Coding and Architecture	Non-compliant	Medium	Add a patch SLA to SECURITY.md (e.g. critical 7 days, high 30).	No documented remediation time frames for vulnerable components.	open
V15.1.2 ASVS	An inventory catalog, such as software bill of materials (SBOM), is maintained of all third-party libraries in use, including verifying that... V15 Secure Coding and Architecture	Non-compliant	Medium	Generate a CycloneDX SBOM in CI and keep it with each release.	No SBOM; package-lock.json only.	open
V13.3.1 ASVS	A secrets management solution, such as a key vault, is used to securely create, store, control access to, and destroy backend secrets. These could... V13 Configuration	Partial	Medium	Move to a managed secret store with rotation for the production deployment.	Secrets in Replit Secrets/env; .env.example names only; no vault, rotation or expiry.	open
V13.3.2 ASVS	Access to secret assets adheres to the principle of least privilege. V13 Configuration	Partial	Medium	Restrict browser keys by HTTP referrer and API; verify in the Google and Cesium consoles.	Server keys stay server-side, but GOOGLE_MAPS_API_KEY and CESIUM_ION_TOKEN are bundled to the browser by design.	open
V13.2.5 ASVS	The web or application server is configured with an allowlist of resources or systems to which the server can send requests or load data or files from. V13 Configuration	Partial	Low	Restrict outbound egress to the documented hosts where hosting allows.	No egress restriction at the server or platform level.	open
3.0.13 ED-153	COTS 3 SSAS	Partial	S3	COTS dossiers: CesiumJS, satellite.js, Node, browser, host, feeds.	Licence inventory and data-source register; no COTS dossiers.	open
7.x COTS ED-153	COTS 7 Additional ANS	Partial	S4	COTS dossiers, SBOM, wrappers.	Licence inventory only.	open
7.x SE ED-153	Service experience 7 Additional ANS	Non-compliant	S3	Service history argument where COTS credit claimed.	No service history.	open
4.3.10 ED-153	Standards/rules (incl. PDS/COTS references) 4.3 Development	Partial	S4	Reference PDS/COTS standards and deviations.	Inherited code follows upstream conventions.	open

W4 Logging and monitoring

Wave 1 · 11 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V16.1.1 ASVS	An inventory exists documenting the logging performed at each layer of the application's technology stack, what events are being logged, log formats,... V16 Security Logging and Error Handling	Non-compliant	Medium	Document what each layer logs, where, and retention.	No log inventory.	open
V16.3.3 ASVS	The application logs the security events that are defined in the documentation and also logs attempts to bypass the security controls, such as input... V16 Security Logging and Error Handling	Non-compliant	Medium	Log rate-limit and validation rejects as security events.	No security events defined or logged (rate-limit hits, validation rejects).	open
V16.4.3 ASVS	Logs are securely transmitted to a logically separate system for analysis, detection, alerting, and escalation. The aim is to ensure that if the... V16 Security Logging and Error Handling	Non-compliant	Medium	Forward logs to a SIEM or log service with alerting.	No log shipping to a separate system.	open
V16.2.1 ASVS	Each log entry includes necessary metadata (such as when, where, who, what) that would allow for a detailed investigation of the timeline when an... V16 Security Logging and Error Handling	Partial	Low	Adopt structured JSON logs with timestamp and request id.	console.warn/error lines carry provider and reason, but no structured when/where metadata.	open
V16.2.2 ASVS	Time sources for all logging components are synchronized, and that timestamps in security event metadata use UTC or include an explicit time zone... V16 Security Logging and Error Handling	Partial	Low	Emit ISO-8601 UTC timestamps.	Relies on platform timestamps; no explicit UTC in log lines.	open
V16.2.4 ASVS	Logs can be read and correlated by the log processor that is in use, preferably by using a common logging format. V16 Security Logging and Error Handling	Partial	Low	Use JSON lines.	Free-text console logs; no common format.	open
V16.4.1 ASVS	All logging components appropriately encode data to prevent log injection. V16 Security Logging and Error Handling	Partial	Low	Encode or JSON-stringify untrusted values in logs.	Some feed-derived strings logged without encoding.	open
V16.4.2 ASVS	Logs are protected from unauthorized access and cannot be modified. V16 Security Logging and Error Handling	Partial	Low	Ship logs to an append-only store.	Logs protected only by platform access control; not tamper-evident.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
3.0.11 ED-153	SWAL monitoring 3 SSAS	Non-compliant	S2	Telemetry and incident log mapped to SWAL.	No in-service malfunction monitoring.	open
4.4.5 ED-153	Performance monitoring 4.4 Operation	Non-compliant	S3	Telemetry and feed-health indicators.	No performance or feed-health monitoring.	open
4.4.4 ED-153	Software operation 4.4 Operation	Partial	S4	Operating procedures and logs.	Server logs only.	open

W5 Access control

Wave 2 · 2 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V8.1.1 ASVS	Authorization documentation defines rules for restricting function-level and data-specific access based on consumer permissions and resource attributes. V8 Authorization	Non-compliant	High	Define roles (viewer, operator, admin) and which functions each may use.	No authorization model documented; the app is public-by-design (SECURITY.md known gap 1).	open
V8.2.1 ASVS	The application ensures that function-level access is restricted to consumers with explicit permissions. V8 Authorization	Non-compliant	High	Put authentication (SSO/OIDC) in front of the app before any non-public deployment.	Every function, including cost-bearing API proxies and Exercise mode, is open to anyone with the URL.	open

W6 Data and validation rules

Wave 1 · 4 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V2.1.1 ASVS	The application's documentation defines input validation rules for how to check the validity of data items against an expected structure. This could... V2 Validation and Business Logic	Partial	Medium	Write an input-validation spec per API endpoint (types, ranges, lengths).	Validation exists in code (400 on bad hex, callsign, coordinates, cyclone query) but rules are not documented.	open
V2.1.2 ASVS	The application's documentation defines how to validate the logical and contextual consistency of combined data items, such as checking that suburb... V2 Validation and Business Logic	Partial	Low	Add to the validation spec.	Combined-field checks exist in code (bbox, route coords); not documented.	open
V14.1.1 ASVS	All sensitive data created and processed by the application has been identified and classified into protection levels. This includes data that is... V14 Data Protection	Non-compliant	Medium	Classify data (public, aggregated-sensitive, simulated) and record handling rules.	No data classification. Public OSINT, but aggregated military tracks may be sensitive to a defence customer.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
V14.1.2 ASVS	All sensitive data protection levels have a documented set of protection requirements. This must include (but not be limited to) requirements related... V14 Data Protection	Non-compliant	Medium	Define per-class requirements (retention, caching, export).	No protection requirements per level.	open

W7 Safety analysis

Wave 3 · 10 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
3.1.2 ED-153	Operational environment 3.1 Initiation	Partial	S3	ConOps: users, environment, advisory-only boundary.	Demo use described; no operational concept.	open
3.1.5 ED-153	System FHA & PSSA output 3.1 Initiation	Non-compliant	S2	FHA with the customer.	No FHA/PSSA.	open
4.1.2 ED-153	Functional Hazard Assessment 4.1 Acquisition	Non-compliant	S2	FHA (shared with 3.1.5).	No FHA.	open
3.3.1 ED-153	Failures identification 3.3 Requirements	Non-compliant	S2	Failure modes per component.	No software failure-mode list.	open
3.3.2 ED-153	Failure effects 3.3 Requirements	Non-compliant	S2	Effects of each failure on users.	No effects analysis.	open
3.3.3 ED-153	Assessment of risk 3.3 Requirements	Non-compliant	S2	Likelihood justification.	No risk assessment.	open
3.0.5 ED-153	SWAL allocation 3 SSAS	Non-compliant	S2	Hazard log and severity x likelihood allocation.	SWAL set top-down; no hazard analysis.	open
3.3.5 ED-153	SWAL allocation 3.3 Requirements	Non-compliant	S2	Allocation per failure.	No allocation record.	open
4.1.3 ED-153	Preliminary System Safety Assessment 4.1 Acquisition	Non-compliant	S2	PSSA after the FHA.	No PSSA.	open
3.3.4 ED-153	Software requirements setting 3.3 Requirements	Partial	S3	GEV-SAF tier traced into the SRS.	Functional requirements exist; no safety requirements.	open

W8 Safety plan, process and configuration management

Wave 3 · 29 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
3.0.1 ED-153	Implementation of the SSAS 3 SSAS	Non-compliant	S2	Write the SSAS into a software safety assessment plan.	No documented software safety assurance system.	open
3.2.1 ED-153	Approach 3.2 Planning	Partial	S3	Software safety assessment approach.	Approach in VERIFICATION.md.	open
3.2.2 ED-153	Plan 3.2 Planning	Partial	S3	Software safety assessment plan.	Verification plan only.	open
3.2.3 ED-153	Plan review 3.2 Planning	Non-compliant	S2	Named reviewer signs off the plan.	No independent plan review.	open
3.2.4 ED-153	Plan dissemination 3.2 Planning	Partial	S3	Distribution record.	Plans in the repo.	open
3.0.8 ED-153	Assurance rigour objective 3 SSAS	Partial	S3	State SWAL-scaled rigour in the plan.	Verification plan exists; rigour not tied to SWAL.	open
3.0.9 ED-153	Assurance rigour criteria 3 SSAS	Partial	S3	Per-objective I/R/D classification in the plan.	Verification method per requirement (T/A/I/D).	open
3.4.3 ED-153	Process assurance 3.4 V&V/PA	Non-compliant	S2	QA audit of the process.	No process audit.	open
4.2.4 ED-153	Planning 4.2 Supply	Partial	S4	Project and development plans.	Readiness report and remediation plan.	open
4.3.3 ED-153	Process implementation 4.3 Development	Partial	S4	Development plan incl. COTS scope and AI-use policy.	CONTRIBUTING and TESTING define the process.	open
4.3.11 ED-153	Requirement development management 4.3 Development	Partial	S4	Requirement change control via issues.	Requirements in git; no change control.	open
3.0.7 ED-153	Configuration management assurance 3 SSAS	Partial	S3	Tag releases; deploy a CI-built artifact.	Build stamp, lockfile, config index. Hosted demo not a clean checkout; no tags.	open
5.2.1 ED-153	Process implementation 5.2 CM	Partial	S4	CM plan.	Configuration index.	open
5.2.3 ED-153	Configuration control 5.2 CM	Partial	S4	Protected main with reviews.	Branch workflow; main unprotected.	open
5.2.x ED-153	Further CM objectives (placeholder) 5.2 CM	Partial	S4	Status accounting and release records.	Results log.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
5.4.13 ED-153	Verification of retrieval and release process 5.4 Verification	Partial	S4	Tagged, reproducible releases.	Clean-clone rebuild verified; no tags.	open
3.0.12 ED-153	Software modifications 3 SSAS	Partial	S3	Per-change impact analysis template.	Branch, clean-clone verify, merge, deploy. No safety impact analysis.	open
3.0.15 ED-153	All on-line aspects of SW operational changes 3 SSAS	Partial	S3	Documented and tested rollback.	Gated deploy procedure; rollback untested.	open
4.4.1 ED-153	Process implementation 4.4 Operation	Partial	S4	Operations plan.	Demo runbook.	open
4.5.1 ED-153	Process implementation 4.5 Maintenance	Partial	S4	Maintenance plan.	Changelog and change process.	open
4.5.2 ED-153	SWAL allocation confirmation 4.5 Maintenance	Non-compliant	S3	Impact analysis per release.	No SWAL re-check per change.	open
4.5.3 ED-153	SWAL satisfaction 4.5 Maintenance	Non-compliant	S3	Release evidence pack.	No per-change SWAL evidence.	open
5.3.x ED-153	Quality assurance (placeholder) 5.3 QA	Non-compliant	S3	QA role, plan and audits.	No QA role or audits.	open
5.8.x ED-153	Problem resolution (placeholder) 5.8 Problem resolution	Partial	S4	Log all known limitations as issues.	Issue template exists; no reports raised.	open
6.1.x ED-153	Management (6.1.5 cited) 6 Organisational	Partial	S4	Project management records.	Plans and tasks tracked informally.	open
6.2.x ED-153	Infrastructure (placeholder) 6 Organisational	Partial	S4	Infrastructure definition.	CI and hosting defined in the config index.	open
6.3.x ED-153	Improvement (6.3.2 cited) 6 Organisational	Partial	S4	Improvement records.	Lessons fed back into gates.	open
6.4.x ED-153	Training (placeholder) 6 Organisational	Non-compliant	S3	Training and competence records.	No competence records.	open
7.x DE ED-153	Development environment 7 Additional ANS	Partial	S4	Environment under CM, incl. AI agent configuration.	Lockfile; Node pinned in engines.	open

W9 Requirements, verification and validation

Wave 3 · 18 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
3.0.2 ED-153	Requirements correctness and completeness 3 SSAS	Partial	S3	Review and approve the SRS; derive safety requirements.	GEV-SRS 0.1 (56 requirements), reverse-engineered, unreviewed.	open
3.0.3 ED-153	Requirements traceability assurance 3 SSAS	Partial	S3	Trace or trim the inherited layer engine.	56/56 requirements traced; trace-check in CI. Inherited engine not traced.	open
3.0.4 ED-153	Unintended functions 3 SSAS	Partial	S3	Deactivated-code review; remove /api/route.	0 orphan files (import-graph gate). /api/route reachable but unused.	open
3.0.14 ED-153	Independence (of components) 3 SSAS	Partial	S3	Isolation argument per first-level component.	Import-direction and package-boundary checks enforce structure.	open
4.3.1 ED-153	System requirements analysis 4.3 Development	Partial	S4	System requirements spec.	System scope in README/ARCHITECTURE.	open
4.3.4 ED-153	SW requirements analysis 4.3 Development	Partial	S4	Reviewed SRS covering the layer engine.	SRS 0.1, 56 requirements.	open
4.3.7 ED-153	SW integration 4.3 Development	Partial	S4	Integration test plan per component boundary.	CI build and test integrate all modules.	open
4.3.14 ED-153	Rationale for design choices (esp. real-time) 4.3 Development	Partial	S4	Design decision records.	Rationale in code comments and docs.	open
3.4.2 ED-153	Verification 3.4 V&V/PA	Partial	S3	Verify safety requirements.	Functional requirements verified by tests.	open
5.4.3 ED-153	Verification of software requirements 5.4 Verification	Partial	S4	Independent review of functional tests.	Requirement-based tests pass; independence contested at SWAL 3.	open
5.4.4 ED-153	Integration verification 5.4 Verification	Partial	S4	Interface tests for every component boundary.	Server proxy and fallback tests.	open
5.4.5 ED-153	Verification of SW architectural design 5.4 Verification	Partial	S4	Architecture review record.	Boundaries verified automatically.	open
5.4.9 ED-153	Data verification 5.4 Verification	Partial	S4	Feed integrity and outage tests.	FEED/SIMULATED tagging and injection tests; no feed integrity checks.	open
5.4.12 ED-153	Verification of verification process results 5.4 Verification	Partial	S4	Verification report.	Results log per commit.	open
3.4.1 ED-153	Validation 3.4 V&V/PA	Non-compliant	S2	Validate GEV-SAF with users.	Safety requirements not validated (none exist).	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
5.5.x ED-153	Validation (placeholder) 5.5 Validation	Non-compliant	S3	Validation with operational users.	No operational validation.	open
5.6.x ED-153	Joint review (placeholder) 5.6 Joint review	Non-compliant	S3	Review minutes with the customer.	No joint reviews.	open
4.4.3 ED-153	User support 4.4 Operation	Partial	S4	User guide and support route.	README, runbook.	open

W10 Safety case and release evidence

Wave 4 · 7 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
3.0.10 ED-153	SWAL assurance 3 SSAS	Non-compliant	S2	Direct and back-up arguments in the SSAR.	No safety argument.	open
3.0.17 ED-153	Argument that SWAL objectives are met 3 SSAS	Non-compliant	S2	GSN-style argument in the SSAR.	No argument that SWAL objectives are met.	open
3.4.4 ED-153	Documented outputs as proof requirements are met 3.4 V&V/PA	Partial	S3	Safety assessment report.	Gap analysis and readiness report.	open
3.5.1 ED-153	Document process results 3.5 Completion	Partial	S4	Assessment report per release.	Results log per commit.	open
3.5.3 ED-153	Documentation dissemination 3.5 Completion	Partial	S4	Distribution record.	Docs in the repo and project.	open
5.7.2–5.7.4 ED-153	Audit (numbers only) 5.7 Audit	Partial	S4	Independent audit.	Self-assessment only.	open
8 ED-153	Safety Folder 8 Safety Folder	Partial	S3	Software Safety Folder / SSAR.	Folder index in the gap analysis.	open

W11 AI management system

Wave 2 · 33 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
C4.1 ISO 42001	Organisation and its context C4 Context	Non-compliant	Medium	Write the AI context statement as part of the AIMS manual.	No analysis of the organisation's context for AI (purpose, climate, legal and contractual factors).	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
C4.2 ISO 42001	Interested parties and their needs C4 Context	Non-compliant	Medium	Register interested parties and their requirements.	Interested parties (operators, customer, regulators, people under surveillance) and their AI expectations are not listed.	open
C4.3 ISO 42001	Scope of the AI management system C4 Context	Non-compliant	High	Define and document the AIMS scope and its boundaries.	No defined scope for an AI management system: which AI uses (Director, narration, AI coding, HENRI) are covered is undecided.	open
C4.4 ISO 42001	AI management system established C4 Context	Non-compliant	Medium	Establish the AIMS: manual, processes and their interactions.	No AI management system exists.	open
C5.1 ISO 42001	Leadership and commitment C5 Leadership	Partial	Medium	Record leadership commitment and resourcing for the AIMS.	Owner approval of the remediation plan shows commitment, but no AI-specific leadership commitment is recorded.	open
C5.2 ISO 42001	AI policy C5 Leadership	Non-compliant	High	Issue an AI policy: purpose, advisory-only boundary, principles, commitments to requirements and improvement.	No AI policy.	open
C5.3 ISO 42001	Roles, responsibilities and authorities C5 Leadership	Non-compliant	Medium	Assign AIMS owner, AI risk owner and approver roles.	No AI roles or authorities assigned.	open
C6.2 ISO 42001	AI objectives and plans C6 Planning	Non-compliant	Medium	Set AI objectives with measures and owners.	No measurable AI objectives.	open
C6.3 ISO 42001	Planning of changes C6 Planning	Partial	Low	Add an AI impact check to change planning.	Changes are tracked (changelog, configuration index, evidence ledger) but not assessed for AI effects.	open
C7.1 ISO 42001	Resources C7 Support	Partial	Low	Allocate AIMS resources.	Engineering resources exist; none allocated to the AIMS.	open
C7.2 ISO 42001	Competence C7 Support	Non-compliant	Low	Define AI competence needs and keep training records.	AI competence of the people building and using the system is not defined or evidenced.	open
C7.3 ISO 42001	Awareness C7 Support	Non-compliant	Low	Brief everyone working on the system on the AI policy.	No AI awareness for staff (policy, their contribution, consequences of non-conformity).	open
C7.4 ISO 42001	Communication C7 Support	Non-compliant	Low	Decide what is communicated about AI, to whom and when.	No AI communication plan.	open
A.2.2 ISO 42001	AI policy A.2 Policies for AI	Non-compliant	High	Issue the AI policy (shared with clause 5.2).	No documented AI policy.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
A.2.3 ISO 42001	Alignment with other policies A.2 Policies for AI	Non-compliant	Low	Map the AI policy to existing policies.	AI policy alignment with security, privacy and ethics rules not shown.	open
A.2.4 ISO 42001	Review of the AI policy A.2 Policies for AI	Non-compliant	Low	Review the AI policy at planned intervals.	No review cycle for an AI policy.	open
A.3.2 ISO 42001	AI roles and responsibilities A.3 Internal organisation	Non-compliant	Medium	Name AI roles (shared with 5.3).	Nobody is accountable for AI decisions in the product.	open
A.3.3 ISO 42001	Reporting of concerns A.3 Internal organisation	Partial	Medium	Add an AI concern reporting route.	SECURITY.md gives a vulnerability route; there is no route for AI concerns.	open
A.4.2 ISO 42001	Resource documentation A.4 Resources for AI systems	Partial	Medium	Document AI resources in an AI system inventory.	Dependencies and configuration are documented; AI components are not identified as such.	open
A.4.4 ISO 42001	Tooling resources A.4 Resources for AI systems	Partial	Medium	Document AI tooling, versions and permitted use.	AI coding tools (Claude, Replit Agent) are visible in commit trailers but not documented as tooling with versions and limits.	open
A.4.5 ISO 42001	System and computing resources A.4 Resources for AI systems	Partial	Low	Document system and computing resources.	Hosting is known (Replit) but computing resources for AI features are not documented.	open
A.4.6 ISO 42001	Human resources A.4 Resources for AI systems	Non-compliant	Low	Record people, roles and competence.	Human resources and competence for AI are not documented.	open
A.6.1.2 ISO 42001	Objectives for responsible development A.6 AI system life cycle	Partial	Medium	Turn the guardrails into responsible-development objectives.	Ethics guardrails are stated in the README (non-kinetic, no dossiers, FEED/SIMULATED tags) but not as formal objectives.	open
A.6.1.3 ISO 42001	Responsible design and development processes A.6 AI system life cycle	Partial	Medium	Require human review and tests for AI-generated changes.	CI gates and traceability apply to all code; AI-generated changes have no specific review rule.	open
A.8.2 ISO 42001	Documentation and information for users A.8 Information for interested parties	Partial	Medium	Disclose automated selection and synthetic narration; correct the package description.	FEED/SIMULATED labels and known limitations exist, but users are not told selections and narration are automated, and the package still advertises voice control that is not shipped.	open
A.8.3 ISO 42001	External reporting A.8 Information for interested parties	Non-compliant	Low	Identify external reporting duties.	No external reporting obligations identified for AI.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
A.8.5 ISO 42001	Information for interested parties A.8 Information for interested parties	Partial	Low	Plan information for interested parties.	README and runbook inform some parties; no plan for others.	open
A.9.2 ISO 42001	Processes for responsible use A.9 Use of AI systems	Partial	Medium	Document responsible-use processes for operators.	The Director is advisory and any input hands control back, but responsible-use processes are not documented.	open
A.9.3 ISO 42001	Objectives for responsible use A.9 Use of AI systems	Non-compliant	Low	Set responsible-use objectives.	No objectives for responsible use.	open
A.9.4 ISO 42001	Intended use A.9 Use of AI systems	Partial	High	Publish an intended-use statement, including prohibited uses.	The advisory-only, non-kinetic boundary is stated, but there is no formal intended-use statement with prohibited uses.	open
A.10.2 ISO 42001	Allocation of responsibilities A.10 Third parties and customers	Non-compliant	Medium	Allocate AI responsibilities in contracts and the AIMS.	Responsibilities between Digital Dynamics Group, AI suppliers and customers are not allocated.	open
A.10.3 ISO 42001	Suppliers A.10 Third parties and customers	Non-compliant	High	Assess and register AI suppliers; set terms for data and model use.	AI suppliers (AI coding agents, a future HENRI model provider) are not assessed or managed.	open
A.10.4 ISO 42001	Customers A.10 Third parties and customers	Partial	Medium	Define customer AI obligations and expectations.	Customer-facing limitations exist; AI-specific customer obligations are not defined.	open

W12 AI risk, impact and monitoring

Wave 3 · 20 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
C6.1.1 ISO 42001	Actions on AI risks and opportunities C6 Planning	Non-compliant	Medium	Plan actions on AI risks and opportunities in the AIMS.	AI risks and opportunities are not planned for.	open
C6.1.2 ISO 42001	AI risk assessment C6 Planning	Non-compliant	High	Run and document an AI risk assessment with criteria.	No AI risk assessment (e.g. a wrong automated announcement, misleading narration, unreviewed AI-written code).	open
C6.1.3 ISO 42001	AI risk treatment C6 Planning	Partial	Medium	Add AI risk treatment and a statement of applicability for Annex A.	The CrossCheck remediation plan treats safety and security risks; AI-specific risks have no treatment plan.	open
C6.1.4 ISO 42001	AI system impact assessment C6 Planning	Non-compliant	High	Assess and document impacts on individuals, groups and society.	No AI system impact assessment for the people and groups affected by the display and its announcements.	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
C8.1 ISO 42001	Operational planning and control C8 Operation	Partial	Medium	Define operational controls for AI features and AI-assisted development.	CI gates and traceability control the build, but AI-specific operational controls are not defined.	open
C8.2 ISO 42001	AI risk assessment in operation C8 Operation	Non-compliant	Medium	Schedule AI risk reassessment.	AI risk assessments are not performed at planned intervals.	open
C8.3 ISO 42001	AI risk treatment in operation C8 Operation	Non-compliant	Medium	Implement and track AI risk treatment.	No AI risk treatment in operation.	open
C8.4 ISO 42001	AI system impact assessment in operation C8 Operation	Non-compliant	Medium	Repeat impact assessment on significant change.	Impact assessments are not repeated on change.	open
C9.1 ISO 42001	Monitoring, measurement and evaluation C9 Performance evaluation	Non-compliant	Medium	Define and collect AI performance measures.	AI performance (announcement accuracy, false alerts, feed staleness) is not measured.	open
C10.2 ISO 42001	Nonconformity and corrective action C10 Improvement	Partial	Medium	Handle AI nonconformities through the same ledger.	Findings are tracked to closure in the evidence ledger; no AI nonconformity process.	open
A.5.2 ISO 42001	Impact assessment process A.5 Impact assessment	Non-compliant	High	Define the impact assessment process.	No process to assess the impact of AI features (shared with 6.1.4).	open
A.5.3 ISO 42001	Documented impact assessments A.5 Impact assessment	Non-compliant	Medium	Keep impact assessments as documented information.	No impact assessments on record.	open
A.5.4 ISO 42001	Impacts on individuals and groups A.5 Impact assessment	Partial	Medium	Assess impacts on individuals and groups, building on the existing guardrails.	Principles exist (no person dossiers, generic ownership, SIMULATED labels) but impacts on individuals are not assessed.	open
A.5.5 ISO 42001	Societal impacts A.5 Impact assessment	Non-compliant	Medium	Assess societal and dual-use impacts.	Societal effects of a public military-asset picture with automated announcements are not assessed.	open
A.6.2.4 ISO 42001	Verification and validation A.6 AI system life cycle	Partial	Medium	Validate announcements against feeds and with users.	Director rules are unit-tested; no validation that announcements are accurate and useful.	open
A.6.2.5 ISO 42001	Deployment A.6 AI system life cycle	Partial	Medium	Define AI release criteria.	Deployed to Replit without release criteria for AI features.	open
A.6.2.6 ISO 42001	Operation and monitoring A.6 AI system life cycle	Non-compliant	Medium	Monitor AI features in operation (shared with feed-health telemetry).	AI features are not monitored in operation (false or missed announcements, stale feeds).	open

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
A.6.2.8 ISO 42001	Event logs A.6 AI system life cycle	Non-compliant	Medium	Log automated selections and announcements with their inputs.	No event logs of what the Director announced and why.	open
A.7.4 ISO 42001	Data quality A.7 Data for AI systems	Partial	Medium	Set data-quality requirements for decision inputs.	Records are validated and stale data is flagged, but data-quality requirements for automated decisions are not set.	open
A.8.4 ISO 42001	Communication of incidents A.8 Information for interested parties	Non-compliant	Medium	Define AI incident communication.	No plan to communicate AI incidents to users or customers.	open

W13 AIMS audit and review

Wave 4 · 3 findings

ID	REQUIREMENT	BASELINE	SEVERITY	FIX	BASELINE EVIDENCE	CLOSED BY
C9.2 ISO 42001	Internal audit C9 Performance evaluation	Partial	Medium	Plan internal AIMS audits; keep CrossCheck as the method.	The CrossCheck audit is an internal audit, but there is no AIMS audit programme.	open
C9.3 ISO 42001	Management review C9 Performance evaluation	Non-compliant	Low	Hold and minute AIMS management reviews.	No management review of AI.	open
C10.1 ISO 42001	Continual improvement C10 Improvement	Partial	Low	Extend it to the AIMS.	The audit-to-compliance pipeline shows continual improvement for safety and security.	open

How CrossCheck rates and decides

Status scale

Compliant	Fully met, with evidence.
Largely	Met with minor, non-blocking gaps.
Partial	Some evidence; material gaps remain.
Non-compliant	Not met, or no evidence.

Weighted readiness: Compliant 1, Largely 0.75, Partial 0.4, Non-compliant 0, averaged over rated items in scope.

Severity

Safety findings S1–S4 after EASA AMC 20-189 (S1–S2 block a claim). Security and AI findings Critical, High, Medium, Low (Critical and High block a level or conformity).

Verdict rules

ED-153 SWAL claim supported only if every required objective is at least Largely, no S1–S2 finding is open, and independence is evidenced where the SWAL requires it.

ASVS level met only if every requirement at or below the level passes or largely passes, and no Critical or High finding is open.

ISO 42001 met only if every clause 4–10 requirement and every applicable Annex A control conforms or largely conforms, and no High finding is open. Excluded controls need a reason in the statement of applicability.

Evidence rules

The ledger (`docs/evidence/ledger.json`) is the single source of truth. History is append-only. Every status change cites a commit, test, document or review record.

Sources

ED-153 objectives reconstructed from EUROCONTROL *Recommendations for ANS Software* (2005), the Czech CAA ED-153 guide and EASA AMC/GM to Regulation (EU) 2017/373; confirm against ED-153 before any formal claim. OWASP ASVS 5.0.0, © OWASP Foundation, CC BY-SA 4.0. ISO/IEC 42001:2023 is cited by clause and control number with paraphrased titles only; confirm against a purchased copy.